

A Note on “Designing Anonymous Signature-Based Identity Authentication Scheme for Ocean Multilevel Transmission”

Zhengjun Cao, Lihua Liu

Abstract. We show that the authentication scheme (IEEE Internet Things J., 24310-24322, 2024) cannot be practically implemented, because it misused the elliptic curve group law—point multiplication, which is represented as kP , where k is an integer and P is a point on an elliptic curve. But the scheme uses the false representation Q_iQ_j to construct verification equations, where Q_i and Q_j are two points. Besides, we find that an adversary can retrieve the target relay device’s secret key using the intercepted message via open channels.

Keywords: Authentication, Anonymity, Elliptic curve group, Point multiplication.

1 Introduction

Recently, Ye et al. [2] have presented a signature-based identity authentication scheme. It is designed to achieve one-way authentication, forward secrecy, anonymity, and resist replay attack, impersonation attack, etc.

In this note, we show that the authentication scheme cannot be practically implemented, due to the misuse of elliptic curve group law—point multiplication, which is conventionally represented as kP , where k is an integer and P is a point on an elliptic curve E defined over a finite field. But the scheme falsely treats the operation as Q_iQ_j , where Q_i and Q_j are two points. Besides, we find that an adversary can retrieve the target relay device’s secret key by the intercepted message via open channels, due to the misuse of bitwise XOR operator.

2 Review of the Ye et al.’s scheme

Let $E(\mathbb{F}_p)$ be an elliptic curve over the finite field $\mathbb{F}_p$, where p is a big prime. $\mathbb{G}$ is the elliptic curve group with the prime order q , and P is a base point of $\mathbb{G}$. $h : \{0, 1\}^* \rightarrow \{0, 1\}^l$ is a hash function. In the considered scenario, there are three entities: the server, collection devices, and relay nodes. The scheme consists of three phases: system initialization, device registration, authentication and data decryption. It can be described as below.

Initialization. The server picks random numbers $s, K_{pri} \in Z_q^*$ to compute $T_{pub} = s \cdot P$, $K_{pub} = K_{pri} \cdot P$. Publish the system parameters $\{E(\mathbb{F}_p), q, P, K_{pub}, T_{pub}, h\}$.

Z. Cao, Department of Mathematics, Shanghai University, Shanghai, 200444, China.

L. Liu, Department of Mathematics, Shanghai Maritime University, Shanghai, 201306, China.

Email: liulh@shmtu.edu.cn

Registration. Each collection device or relay device sends its identity to the server through a secure channel. The server generates $HID = h(id||s||K_{pri})$ for the collection device. The relay device picks a private key $d_i \in Z_q^*$ and sends $Q_i = d_i \cdot P$ to the server. The server publishes $A_i = K_{pri} \cdot Q_i$.

Authentication. Step 1: The collection device picks a random number $r \in Z_q^*$ and the current timestamp t_1 to compute

$$\begin{aligned} R &= r \cdot P, \quad MID = id \oplus h(r \cdot T_{pub}), \\ MAC &= h(id||HID||t_1||R), \quad key = h(HID||t_1||R). \end{aligned}$$

Encrypt the collected raw data with a symmetric encryption algorithm (AES) to obtain the ciphertext data $\{data\}_{key}$. Send the message

$$\xrightarrow[\text{[open channel]}]{M=\{t_1, R, MAC, MID, \{data\}_{key}\}}$$

to the relay device.

Step 2: The relay device i checks the timestamp t_1 . Then pick a random number $r_i \in Z_q^*$ to compute

$$\begin{aligned} N_i &= r_i \cdot Q_j, \quad R_i = r_i \cdot P, \\ TID_i &= h(id_i||r_i), \quad AID_i = h(N_i) \oplus TID_i, \\ Auth_{ij} &= h(TID_i||R_i||t_3||\textcolor{red}{A}_i\textcolor{red}{Q}_j), \\ sign_i &= h(\textcolor{red}{M}_i \cdot \textcolor{red}{Q}_i) \oplus Auth_{ij}, \\ M_i &= \textcolor{red}{d}_i \cdot M \oplus \textcolor{red}{A}_i\textcolor{red}{Q}_j \end{aligned}$$

where Q_j is the public key of the next device, t_3 is the current timestamp. Send

$$\xrightarrow[\text{[open channel]}]{\{sign_i, M_i, M, R_i, AID_i, t_3\}}$$

to the target next level relay device.

Step 3: The next device j checks the timestamp t_3 . Then compute

$$\begin{aligned} N_j &= d_j \cdot R_i, \quad TID'_i = AID \oplus h(N_j), \\ Auth'_{ij} &= h(TID'_i||R_i||t_3||\textcolor{blue}{A}_j\textcolor{blue}{Q}_i). \end{aligned}$$

Check that

$$h((\textcolor{blue}{M}_i \oplus \textcolor{blue}{A}_j\textcolor{blue}{Q}_i) \cdot P) = sign_i \oplus Auth'_{ij}$$

Then pick a random number $r_j \in Z_q^*$ to compute

$$\begin{aligned} N'_j &= r_j \cdot Q_k, \quad R_j = r_j \cdot P, \\ TID_j &= h(id_j \| r_j), \quad AID_j = h(N'_j) \oplus TID_j, \\ Auth_{jk} &= h(TID_j \| R_j \| t_5 \| A_j Q_k), \\ sign_j &= h(M_i \cdot Q_j) \oplus Auth_{jk}, \\ M_j &= d_j \cdot M_i \oplus A_j Q_k. \end{aligned}$$

Send the message

$$\xrightarrow[\text{[open channel]}]{\{sign_j, M_j, M, R_j, AID_j, t_5\}}$$

to the target next level relay device.

We refer to the page 24314 of Ref.[2] for other steps.

3 False computations

Though the Ye et al.'s scheme is interesting, we find it cannot be practically implemented.

◇ As we see, the relay device i needs to compute the hash value

$$Auth_{ij} = h(TID_i \| R_i \| t_3 \| \textcolor{red}{A_i} \textcolor{red}{Q_j})$$

where $A_i = K_{pri} \cdot Q_i$ and $Q_j = d_j \cdot P$. Both are two points on the underlying elliptic curve. Clearly, the calculation $\textcolor{red}{A_i} \textcolor{red}{Q_j}$ makes no sense. The scheme has confused point addition with point multiplication [1]. The following presentations (see page 24315, Ref.[2])

$$\begin{aligned} A_i Q_j &= K_{pri} \cdot Q_i Q_j = K_{pri} \cdot Q_j Q_i = A_j Q_i, \\ Auth'_{ij} &= Auth_{ij}, \\ sign_i \oplus Auth'_{ij} &= h(M \cdot Q_i) \oplus Auth_{ij} \oplus Auth'_{ij} \\ &= h(M \cdot Q_i), \\ h((M_i \oplus A_j Q_i) \cdot P) &= h((d_i \cdot M \oplus A_i Q_j \oplus A_j Q_i) \cdot P) \\ &= h((d_i \cdot M) \cdot P) = h(M \cdot Q_i), \end{aligned}$$

are false.

If it is revised as $A_i + Q_j$, then we have

$$\begin{aligned} Auth_{ij} &= h(TID_i \| R_i \| t_3 \| \textcolor{red}{A_i} + \textcolor{red}{Q_j}), \\ Auth'_{ij} &= h(TID'_i \| R_i \| t_3 \| \textcolor{blue}{A_j} + \textcolor{blue}{Q_i}). \end{aligned}$$

Since

$$\begin{aligned} A_i + Q_j &= (K_{pri} d_i + d_j) P, \\ A_j + Q_i &= (K_{pri} d_j + d_i) P, \\ A_i + Q_j &\neq A_j + Q_i, \end{aligned}$$

the next level relay device j will fail to check the verification equation and cannot authenticate the collection device.

◇ The representation

$$M_i = d_i \cdot M \oplus A_i Q_j$$

makes no sense except for the false calculation $A_i Q_j$. It falsely treats $d_i \cdot M$ as a point on the underlying elliptic curve. In fact,

$$M = \{t_1, R, MAC, MID, \{data\}_{key}\},$$

$$d_i \cdot M = \{d_i t_1, d_i \cdot R, d_i \cdot MAC, d_i \cdot MID, d_i \cdot \{data\}_{key}\},$$

is not a point on the underlying elliptic curve.

4 Misuse of bitwise XOR

It is well known that the bitwise XOR, $\oplus$, compares two input bits and generates one output bit. If it is performed on two strings, the shorter is padded with some 0s, and the partial string corresponding to the padding bits is directly exposed. For example, the software Mathematica pads 0s to its left side by default (see the below Mathematica codes).

```
a = 289; b = 35;
IntegerString[{a, b, BitXor[a, b]}, 2]

{100100001, 100011, 100000010}
```

The substring “100” of “100100001” is directly copied into the output string “100000010”.

Based on this observation, we find that the following calculation cannot mask the private key

$$\begin{aligned} M_i &= d_i \cdot M \oplus (A_i + Q_j) \\ &= (d_i t_1 \| d_i \cdot R \| d_i \cdot MAC \| d_i \cdot MID \| d_i \cdot \{data\}_{key}) \\ &\quad \oplus (A_i + Q_j) \\ &= d_i t_1 \| d_i \cdot R \| d_i \cdot MAC \| d_i \cdot MID \| \\ &\quad (d_i \cdot \{data\}_{key} \oplus (A_i + Q_j)), \end{aligned}$$

because the string length of $d_i \cdot \{data\}_{key}$ is longer than that of point $A_i + Q_j$.

An adversary who has intercepted the message

$$\{sign_i, M_i, M, R_i, AID_i, t_3\}$$

can retrieve the relay device’s private key d_i by parsing M_i to get the item $d_i t_1$. Since the timestamp t_1 is publicly known to other entities, the adversary can recover d_i from $d_i t_1$. Thus, the target relay device’s secret key will be exposed. The security argument for Theorem 2 (see page 24316, Ref.[2]) becomes illogical. The experimental results (see Fig 5, Fig 6, Fig 7, Ref.[2]) are misleading.

5 Conclusion

We show that the Ye et al.’s authentication scheme cannot be implemented due to some flaws. We find that some newcomers are still unfamiliar with some basic operations, such as point addition, point multiplication for elliptic curve groups, and bitwise XOR. We hope the findings in this note could be helpful for the future work on designing such schemes.

References

- [1] D. Hankerson, A. Menezes, and S. Vanstone. *Guide to Elliptic Curve Cryptography*. Springer, USA, 2004.
- [2] Jun Ye, Xinhui Cao, and Shaoxiong Xie. Designing anonymous signature-based identity authentication scheme for ocean multilevel transmission. *IEEE Internet Things J.*, 11(13):24310–24322, 2024.